Insper

Avaliação Final

Professor Rodolfo Avelino – Tecnologias Hackers

Testes de segurança ofensivos com apoio de Inteligência Artificial

Objetivo

Nesta avaliação, cada grupo deverá realizar testes de segurança em um ambiente local controlado, utilizando os conhecimentos desenvolvidos ao longo da disciplina e investigando como um modelo de linguagem local pode apoiar diferentes etapas de um teste ofensivo.

A atividade busca relacionar os conhecimentos técnicos de segurança com o uso de Inteligência Artificial, por meio do desenvolvimento de um agente supervisionado capaz de interagir com ferramentas de segurança, interpretar os resultados obtidos e propor novas ações durante a investigação.

O objetivo não é simplesmente executar testes ou identificar o maior número possível de vulnerabilidades, mas compreender em quais situações a IA contribui para o processo de investigação, quais são suas limitações e quando o conhecimento técnico e a intervenção humana continuam necessários.

A avaliação busca analisar a capacidade do grupo de:

- planejar e executar testes de segurança;
- formular hipóteses a partir das informações obtidas;
- selecionar e integrar ferramentas de segurança a um modelo de linguagem local;

- desenvolver um agente supervisionado capaz de propor ações a partir dos resultados obtidos;
- avaliar criticamente as sugestões e decisões produzidas pela IA;
- documentar evidências que sustentem suas conclusões.

O grupo não precisa demonstrar que a IA foi melhor. Deverá demonstrar, com evidências, onde ela ajudou, onde falhou e em quais situações a intervenção humana continuou necessária.

1 - Preparação do laboratório

Cada grupo deverá preparar, no próprio kit de laboratório utilizado durante a disciplina, um ambiente controlado para a realização dos testes de segurança com apoio de um modelo de linguagem local.

O ambiente deverá conter:

1. **OWASP Juice Shop:** uma instância local da aplicação vulnerável, acessível a partir do Kali e utilizada exclusivamente como alvo dos testes.
2. **Modelo de linguagem local:** um LLM, como o Qwen3 4B quantizado, executado por meio do Ollama ou solução equivalente. O modelo deverá estar disponível para integração com o programa desenvolvido pelo grupo.
3. **Ferramentas de segurança:** um conjunto de ferramentas que permita investigar a aplicação, realizar requisições, coletar informações e testar hipóteses. A seleção das ferramentas será realizada pelo grupo, considerando os objetivos da avaliação.
4. **Agente de IA supervisionado:** o grupo deverá desenvolver um programa que integre o modelo de linguagem local a um conjunto limitado de ferramentas de segurança. O agente deverá ser capaz de analisar as

informações obtidas, selecionar uma ferramenta disponível e propor uma ação para dar continuidade à investigação.

A execução das ações deverá ser supervisionada pelo grupo, que poderá autorizar, modificar ou rejeitar as sugestões apresentadas. Os resultados das ferramentas deverão retornar ao modelo, permitindo que ele interprete as novas evidências e proponha os próximos passos.

Não será necessário desenvolver um agente completamente autônomo. Entretanto, espera-se que as decisões do modelo possam variar conforme os resultados obtidos, e não apenas seguir uma sequência fixa de comandos previamente programada.

5. **Registro das execuções:** um mecanismo que permita armazenar as ações propostas pelo agente, as ferramentas selecionadas, os parâmetros utilizados, as decisões de autorização ou rejeição tomadas pelo grupo e os resultados obtidos. Os registros deverão permitir reconstruir o processo de investigação e avaliar como as decisões do modelo influenciaram os testes realizados.
6. **Procedimento de restauração:** uma forma de reiniciar ou restaurar o Juice Shop a um estado conhecido, permitindo repetir os experimentos.

Todos os testes deverão permanecer restritos à instância local do Juice Shop. O agente não deverá possuir autorização para executar ações contra serviços externos ou equipamentos de outros grupos.

Insper

2 - Desenvolvimento do agente supervisionado

O grupo deverá desenvolver um programa que permita ao modelo de linguagem participar da investigação, utilizando ferramentas disponibilizadas no laboratório.

Não será necessário desenvolver novamente ferramentas já existentes. Poderão ser utilizadas ferramentas do Kali Linux, como Nmap e curl, por meio de scripts ou interfaces desenvolvidas pelo grupo.

O agente deverá possuir, no mínimo, duas ferramentas integradas, sendo pelo menos uma capaz de interagir diretamente com o Juice Shop.

O funcionamento esperado é:

1. O agente recebe um objetivo de investigação.
2. O modelo analisa as informações disponíveis e seleciona uma ferramenta.
3. O modelo propõe uma ação e seus parâmetros.
4. O grupo autoriza, modifica ou rejeita a execução.
5. Quando autorizada, a ferramenta é executada e seu resultado retorna ao modelo.
6. O modelo interpreta o resultado e poderá propor uma nova ação.

A escolha da próxima ação deverá considerar as informações obtidas anteriormente. Não será suficiente programar uma sequência fixa de comandos que seja executada independentemente dos resultados.

O grupo deverá definir quais ferramentas serão disponibilizadas ao agente e quais limites serão aplicados às suas ações. Não será necessário fornecer acesso irrestrito ao terminal ou ao sistema operacional.

A arquitetura utilizada fica a critério do grupo. Poderão ser utilizadas bibliotecas, APIs locais e frameworks de agentes, desde que os integrantes consigam explicar seu funcionamento e justificar as decisões de implementação.

3 - Planejamento dos testes

Antes de iniciar os experimentos com o agente, o grupo deverá realizar uma análise inicial do ambiente e elaborar um plano de testes.

O planejamento deverá apresentar:

- quais aspectos da aplicação serão investigados;
- quais hipóteses iniciais serão consideradas;
- quais ferramentas poderão contribuir para a investigação;
- quais evidências serão necessárias para sustentar as conclusões.

O planejamento deverá ser realizado inicialmente **sem o apoio do LLM**, para registrar a estratégia proposta pelo próprio grupo.

Após esse registro, o modelo poderá ser utilizado para revisar o planejamento, sugerir alternativas ou indicar aspectos que não foram considerados.

O grupo deverá documentar quais sugestões foram aceitas, modificadas ou rejeitadas, apresentando uma justificativa técnica para as decisões.

Não será necessário identificar previamente todas as vulnerabilidades da aplicação. O planejamento deverá orientar a investigação, permitindo que novas hipóteses sejam formuladas durante os testes.

Insper

4 - Execução dos testes

O grupo deverá realizar **três investigações de segurança** na instância local do Juice Shop.

As investigações deverão contemplar situações distintas, permitindo observar o comportamento do agente diante de diferentes problemas.

Sugere-se que sejam escolhidas situações envolvendo:

- reconhecimento e enumeração da aplicação;
- mecanismos de autenticação ou autorização;
- tratamento de entradas, requisições ou acesso a recursos.

Os grupos poderão escolher outras situações, desde que justifiquem sua relevância e utilizem conhecimentos desenvolvidos durante a disciplina.

Para cada investigação, deverá ser registrado:

1. **Hipótese inicial:** o que o grupo pretende investigar e por quê.
2. **Estratégia proposta:** como o grupo realizaria o teste.
3. **Contribuição do agente:** quais ações ou ferramentas foram sugeridas pelo modelo.
4. **Execução:** quais ações foram efetivamente realizadas e quais resultados foram obtidos.
5. **Intervenção humana:** quais decisões foram aceitas, modificadas ou rejeitadas pelo grupo.
6. **Conclusão:** o que as evidências permitem afirmar e quais limitações permanecem.

Insper

Não será necessário que todas as investigações resultem na confirmação de uma vulnerabilidade.

Uma hipótese rejeitada a partir de evidências também constitui um resultado válido.

5 - Registro das ações e evidências

Todas as ações relevantes realizadas durante os testes deverão ser registradas de forma que seja possível reconstruir o processo de investigação.

Os registros deverão permitir identificar:

- a ação proposta pelo agente;
- a ferramenta e os parâmetros selecionados;
- a decisão de autorização, modificação ou rejeição;
- o resultado produzido pela ferramenta;
- a interpretação apresentada pelo modelo;
- a decisão tomada pelo grupo após analisar o resultado.

O formato dos registros poderá ser definido pelo grupo, utilizando arquivos de texto, JSON, CSV ou outra estrutura.

Não será necessário transcrever integralmente todas as interações com o modelo no relatório. Entretanto, os registros completos deverão estar disponíveis para consulta e verificação.

As conclusões deverão estar relacionadas às evidências efetivamente obtidas. Uma sugestão do modelo, por si só, não será considerada evidência de vulnerabilidade.

Insper

6 - Análise crítica da utilização da IA

Após os testes, o grupo deverá analisar criticamente a contribuição do modelo de linguagem para a investigação.

A análise deverá considerar:

- Em quais situações o modelo apresentou sugestões tecnicamente adequadas?
- O agente conseguiu selecionar ferramentas coerentes com os objetivos dos testes?
- Os resultados obtidos influenciaram suas decisões seguintes?
- O modelo apresentou interpretações incorretas ou conclusões sem evidências?
- Houve ações repetitivas, desnecessárias ou inadequadas?
- Em quais situações a intervenção humana foi necessária?
- Quais limitações foram observadas no modelo e na integração desenvolvida?

O grupo deverá apresentar pelo menos **um exemplo concreto de limitação, erro ou dificuldade observada durante o uso da IA**, explicando como identificou o problema e como lidou com ele.

A análise deverá comparar a estratégia inicialmente elaborada pelo grupo com as contribuições e decisões apresentadas pelo agente.

Essa comparação não precisa demonstrar superioridade de uma abordagem sobre a outra. O objetivo é compreender as possibilidades e os limites da utilização de modelos de linguagem em testes de segurança.

Insper

7 - Entregáveis

Cada grupo deverá entregar:

1. Laboratório reproduzível

Instruções e configurações necessárias para executar o Juice Shop, o modelo local e o agente supervisionado no kit de laboratório.

2. Código do agente

Código-fonte do programa desenvolvido, incluindo as integrações com as ferramentas de segurança e as instruções necessárias para sua execução.

3. Registros dos testes

Evidências das três investigações, incluindo ações propostas, decisões tomadas, ferramentas utilizadas e resultados obtidos.

4. Relatório técnico de 4 a 6 páginas

O relatório deverá apresentar a arquitetura do laboratório, a estratégia de testes, os resultados das investigações e a análise crítica da contribuição da IA.

O documento deverá priorizar a interpretação dos resultados e as evidências, evitando descrições extensas de instalação ou capturas de tela sem análise.

5. Vídeo com apresentação de até 10 minutos

Insper

O grupo deverá demonstrar o funcionamento do agente e apresentar pelo menos uma investigação completa, desde a hipótese inicial até a conclusão, destacando as decisões tomadas pelo modelo e as intervenções realizadas pelo grupo.

8 - Critérios de avaliação

Critério	Peso
Funcionamento e reprodução do laboratório	15%
Desenvolvimento e integração do agente supervisionado	20%
Planejamento e qualidade técnica dos testes	20%
Qualidade das evidências e interpretação dos resultados	20%
Análise crítica da contribuição da IA	20%
Documentação e apresentação	5%
Total	**100%**

O grupo não será avaliado pela quantidade de vulnerabilidades identificadas ou pelo nível de autonomia alcançado pelo agente.

A avaliação considerará principalmente a qualidade dos testes realizados, a capacidade de supervisionar as ações propostas pela IA e a consistência das conclusões apresentadas.

Orientação final

O objetivo desta avaliação não é desenvolver uma IA capaz de realizar testes ofensivos sem supervisão.

Espera-se que o grupo desenvolva uma solução na qual o modelo consiga participar das decisões técnicas, selecionar ferramentas e interpretar resultados, enquanto os

Insper

estudantes permanecem responsáveis pela condução, validação e segurança dos experimentos.

Uma investigação que não confirme uma vulnerabilidade, mas apresente hipóteses bem formuladas, testes adequados e conclusões sustentadas por evidências, poderá ser tão relevante quanto uma investigação que identifique uma falha de segurança.